SYSTEMS AND SERVICES ACQUISITION

WyIT - 3011

PURPOSE: This policy ensures that IT resources and systems are acquired with security requirements to meet the information systems mission and business objectives.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by the WyIT - 3002 - Security Exception Request policy.

IV. ALLOCATION OF RESOURCES

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Determine information security requirements for the information system or information system service in mission/business process planning.
- Determine, document, and allocate the resources required to protect the information system or information system service as part of its capital planning and investment control process.

V. SYSTEM DEVELOPMENT LIFE CYCLE

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall develop a contingency plan for the information system that:

- Manages the information system using the system development life cycle to ensure incorporation of information security considerations.
- Defines and documents information security roles and responsibilities throughout the system development life cycle.
- Identifies individuals having information security roles and responsibilities
- Integrates the information security risk management process into system development life cycle activities.

VI. ACQUISITION PROCESS

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall ensure the acquisition process includes the following requirements:

Descriptions and criteria, explicitly or by reference, in the acquisition contract for the information system, system component, or information system service.
Shall be in accordance with all applicable federal, state, and local laws, Executive Orders, directives, policies, regulations, standards, guidelines, and mission and business needs.

- Security functional requirements.
- Security strength requirements.
- Security assurance requirements.
- Security-related documentation requirements.
- Requirements for protecting security-related documentation.
- Description of the information system development environment and environment in which the system is intended to operate.
- Acceptance criteria.

VII. SECURITY CONTROLS

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall require the information system, or system component, information system service to comply with the following security controls:

- Describe the functional properties of the security controls to be employed, security-relevant external system interfaces, high-level design, low-level design, source code, or hardware schematics that meet the business requirements.
- Identify early in the system development life cycle the functions, ports, protocols, and services intended for organizational use.
- Employ only information technology products on the Federal Information Publication Standards Publication (FIPS) 201-3 approved products list for Personal Identity Verification (PIV) capability implemented within information systems.

VIII. INFORMATION SYSTEM DOCUMENTATION

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Obtain administrator documentation for the information system, system component, or information system service that describes:
  - Secure configuration, installation, and operation of the system, component, or service.
  - Effective use and maintenance of security functions/mechanisms.
  - Known vulnerabilities regarding configuration and use of administrative (i.e., privileged) functions.
- Obtain user documentation for the information system, system component, or information system service that describes:
  - User-accessible security functions/mechanisms and how to effectively use those security functions/mechanisms.
  - Methods for user interaction, which enables individuals to use the system, component, or service in a more secure manner.
  - User responsibilities in maintaining the security of the system, component, or service.
- Document attempts to obtain information system, system component, or information system service documentation when such documentation is either unavailable or nonexistent and in response.

- Protect documentation as required in accordance with the risk management strategy.
- Distribute documentation to only authorized persons or affiliates.

IX. SECURITY ENGINEERING PRINCIPLES

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Apply industry-standard information system security engineering principles in the specification, design, development, implementation, and modification of the information system

X. EXTERNAL INFORMATION SYSTEM SERVICES

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Require that providers of external information system services comply with organizational information security requirements and employ security controls in accordance with applicable federal laws, executive orders, directives, policies, regulations, standards, and guidance.
- Define and document government oversight and user roles and responsibilities with regard to external information system services.
- Employ processes, methods, and techniques to monitor security control compliance by external service providers on an ongoing basis.
- Require providers of external information system services to identify the functions, ports, protocols, and other services required for the use of such services.

XI. DEVELOPER CONFIGURATION MANAGEMENT

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Ensure developers of the information system, system component, or information system service:

    - Perform configuration management during system, component, or service design; development, implementation, and/or operation.
    - Document, manage, and control the integrity of changes to configuration items under configuration management.
    - Implement only organization-approved changes to the system, component, or service.
    - Document approved changes to the system, component, or service and the potential security impacts of such changes.
    - Track security flaws and flaw resolution within the system, component, or service and report findings to authorized personnel and/or business units.
- Require the developer of the information system, system component, or information system service to enable integrity verification of software and firmware components.
- Provide an alternate configuration management process using organizational personnel in the absence of a dedicated developer configuration management team.
- Require the developer of the information system, system component, or information system service to enable integrity verification of hardware components.
- Require the developer of the information system, system component, or information system service to employ tools for comparing newly generated versions of security-relevant hardware descriptions and software/firmware source and object code with previous versions.
- Require the developer of the information system, system component, or information system service to maintain the integrity of the mapping between the master build data (hardware drawings and software/firmware code) describing the current version of security-relevant hardware, software, and firmware and the on-site master copy of the data for the current version.
- Require the developer of the information system, system component, or information system service to execute procedures for ensuring that security-relevant hardware, software, and firmware updates distributed to the organization are exactly as specified by the master copies.

XII. DEVELOPER SECURITY TESTING AND EVALUATION

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall require the developer of the information system, system component, or information system service to:

- Create and implement a security assessment plan.
- Perform unit, integration, system, and regression testing/evaluation.
- Produce evidence of the execution of the security assessment plan and the results of the security testing/evaluation.
- Implement a verifiable flaw remediation process.
- Correct flaws identified during security testing/evaluation.
- Employ static code analysis tools to identify common flaws and document the results of the analysis.
- Perform threat and vulnerability analyses and subsequent testing/evaluation of the as-built system, component, or service.

XIII. INDEPENDENT VERIFICATION OF ASSESSMENT PLANS / EVIDENCE

All applicable agencies, affiliates, and information system owners identified in the scope of this policy shall:

- Require an independent agent to verify the correct implementation of the developer security assessment plan and the evidence produced during security testing/evaluation.
- Ensure that the independent agent either is provided with sufficient information to complete the verification process or has been granted the authority to obtain such information.
- Perform a manual code review of defined processes, procedures, and/or techniques.
- Perform penetration testing in coordination with the Office of the CIO: A test methodology in which assessors, using all available documentation (e.g., system design, (SOURCE code, manuals) and working under specific constraints, attempt to circumvent the security features of an information system. (SOURCE: NIST SP 800-53A; NIST SP 800-53; CNSSI-4009)
- Verify that the scope of security testing/evaluation provides complete coverage of required security controls.
- Employ dynamic code analysis tools to identify common flaws and document the results of the analysis.

REFERENCES

- National Institute of Standards and Technology (NIST) / Federal Information Processing Standards (FIPS) 201-3

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
June 2024	ETS Governance, Risk and Compliance	Public Comment Period	05/10/2024 - 05/24/2024	June 2024

REVISIONS		
LAST REVISION DATE	**LAST REVISED BY**	**LAST APPROVED BY**

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**